

Sonde de détection Active - Fail2ban

Introduction

Le principe d'une sonde de détection active est d'offrir un moyen de détecter des schémas d'attaque et d'automatiser la mise en place d'une mesure de sécurité en temps réel.

Au travers de Fail2ban, les mesures de sécurité consistent généralement à ban une adresse IP temporairement pour empêcher notamment les attaques par force brute.

Ce type de mécanisme va grandement réduire la capacité d'un attaquant à opérer à la fois des attaques par force brute mais également des attaques liées à de la reconnaissance (type fuzzing, ...).

Installation

L'installation du package est assez basique.

```
pacman -S fail2ban
```

```
root@test ~]# pacman -S fail2ban
résolution des dépendances■
recherche des conflits entre paquets■

Paquets (4) python-pyinotify-0.9.6-12  python-systemd-235-2  whois-5.5.17-1  fail2ban-1.0.2-4

Taille totale du téléchargement : 1,02 MiB
Taille totale installée : 5,94 MiB

:: Procéder à l'installation ? [O/n]
```

Une fois le package installé, il n'y a plus qu'à démarrer et activer le service.

```
systemctl enable --now fail2ban
```

```
[root@test ~]# systemctl enable --now fail2ban
Created symlink /etc/systemd/system/multi-user.target.wants/fail2ban.service.
[root@test ~]#
```

Configuration

Par défaut, la configuration n'inclut aucune jail.

```
fail2ban-client status
```

```
[root@test ~]# fail2ban-client status
Status
|- Number of jail: 0
`- Jail list:
```

Pour activer une jail, il suffira de retrouver la section correspondante dans le fichier `/etc/fail2ban/jail.conf` et d'y ajouter la mention `enabled = true`

```
[sshd]

enabled = true
# To use more aggressive sshd modes see
```

Après un redémarrage, la jail apparait bien comme étant active.

```
systemctl restart fail2ban
fail2ban-client status
```

```
[root@test ~]# systemctl restart fail2ban
[root@test ~]# fail2ban-client status
Status
|- Number of jail:      1
`- Jail list:  sshd
[root@test ~]#
```

Test de fonctionnement

L'action à prendre par défaut pour la jail sshd est suite à plusieurs tentatives de connexion en échec.

Nous allons donc simplement essayer de nous connecter sur la machine avec un mauvais mot de passe.

```
[root@totoarch ~]# ssh localadm@192.168.154.142
localadm@192.168.154.142's password:
Permission denied, please try again.
localadm@192.168.154.142's password:
Permission denied, please try again.
localadm@192.168.154.142's password:
```

Au bout de quelques tentatives, le serveur nous empêche de nous connecter, la jail fonctionne donc bien.

```
[root@totoarch ~]# ssh localadm@192.168.154.142
ssh: connect to host 192.168.154.142 port 22: Connection refused
[root@totoarch ~]#
```

Il est possible de visualiser les IP qui font l'objet d'une mesure de sécurité (ban).

```
fail2ban-client banned
```

```
[root@test ~]# fail2ban-client banned
[{'sshd': ['192.168.154.180']}]
[root@test ~]#
```

Dans le cas où l'on souhaiterait unban un client, une commande simple existe également.

```
fail2ban-client unban <clientip>
```

```
[root@test ~]# fail2ban-client unban 192.168.154.180
1
[root@test ~]# fail2ban-client banned
[{'sshd': []}]
[root@test ~]#
```

En complément, un fichier de log existe par défaut dans `/var/log/fail2ban.log` et permet de tracker les événements liés à fail2ban. On peut notamment y voir les tentatives qui ont mené au ban de notre IP.

```
[1519]: INFO      [sshd] Jail is in operation now (process new journal entries)
[1519]: INFO      [sshd] Found 192.168.154.180 - 2023-05-25 08:53:28
[1519]: INFO      [sshd] Found 192.168.154.180 - 2023-05-25 08:53:28
[1519]: INFO      [sshd] Found 192.168.154.180 - 2023-05-25 08:53:29
[1519]: INFO      [sshd] Found 192.168.154.180 - 2023-05-25 08:53:29
[1519]: INFO      [sshd] Found 192.168.154.180 - 2023-05-25 08:53:30
[1519]: INFO      [sshd] Found 192.168.154.180 - 2023-05-25 08:53:30
[1519]: NOTICE   [sshd] Ban 192.168.154.180
[1519]: INFO      [sshd] Found 192.168.154.180 - 2023-05-25 08:53:30
```